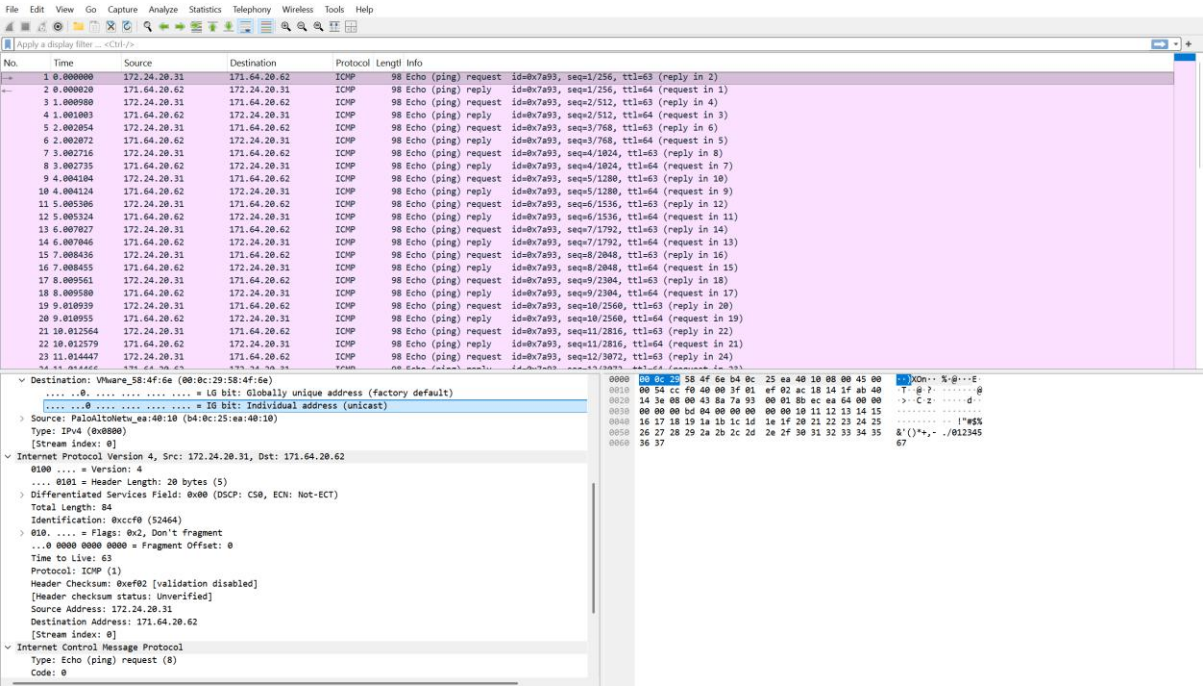


Question 1: Analyse packet1.pcap and find the flag.



Decode from Base64 format

Simply enter your data then push the decode button.

U1VDVEYyMDJzeyFpX2lzX2Nb2x9

ASCII

Source character set.

Decode each line separately (useful for when you have multiple entries).

Live mode OFF

Decodes in real-time as you type or paste (supports only the UTF-8 character set).

< DECODE >

Decodes your data into the area below.

SUCTF2023{li_is_cool}

We already get the flag : SUCTF2023{ai_is_cool}

packet2.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-F>

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=1/256, ttl=63 (reply in 2)
2	0.000020	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=1/256, ttl=64 (request in 1)
3	1.001961	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=2/512, ttl=63 (reply in 4)
4	1.001979	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=2/512, ttl=64 (request in 3)
5	2.003244	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=3/768, ttl=63 (reply in 6)
6	2.003257	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=3/768, ttl=64 (request in 5)
7	3.003351	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=4/1024, ttl=63 (reply in 8)
8	3.003370	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=4/1024, ttl=64 (request in 7)
9	4.004365	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=5/1280, ttl=63 (reply in 10)
10	4.004390	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=5/1280, ttl=64 (request in 9)
11	5.006097	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=6/1536, ttl=63 (reply in 12)
12	5.006117	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=6/1536, ttl=64 (request in 11)
13	6.007736	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=7/1792, ttl=63 (reply in 14)
14	6.007756	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=7/1792, ttl=64 (request in 13)
15	6.933722	172.24.20.31	171.64.20.62	TCP	74	59752 → 4444 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=2741268107 TSecr=0 WS=128
16	6.933749	171.64.20.62	172.24.20.31	TCP	74	4444 → 59752 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3516162405 TSecr=2741268107 WS=128
17	6.934794	172.24.20.31	171.64.20.62	TCP	66	59752 → 4444 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=2741268109 TSecr=3516162405
18	7.009493	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=8/2048, ttl=63 (reply in 19)
19	7.009503	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=8/2048, ttl=64 (request in 18)
20	8.010998	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0xc890, seq=9/2304, ttl=63 (reply in 21)
21	8.011015	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0xc890, seq=9/2304, ttl=64 (request in 20)
22	8.614238	172.24.20.31	171.64.20.62	TCP	72	59752 → 4444 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=2741269788 TSecr=3516162405
23	8.614259	171.64.20.62	172.24.20.31	TCP	66	4444 → 59752 [ACK] Seq=1 Ack=7 Win=65280 Len=0 TSval=3516164085 TSecr=2741269788

Searching tcp.port == 37697 to find the ftp

packet2.pcap

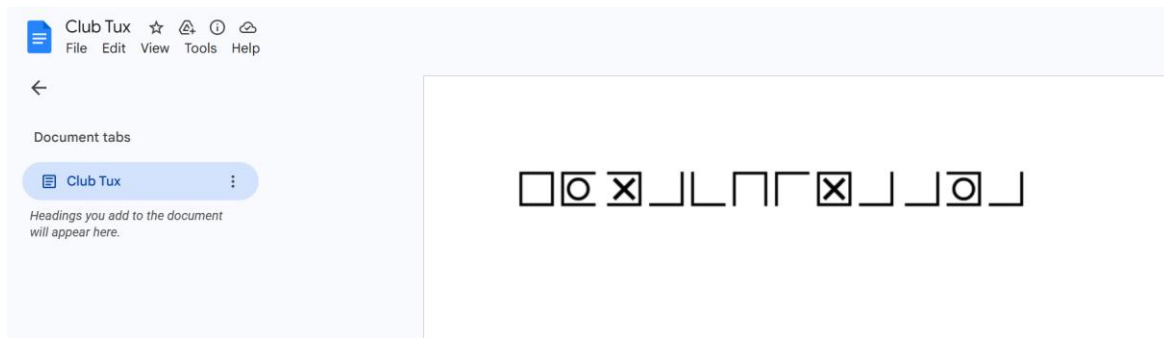
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.port == 37697

No.	Time	Source	Destination	Protocol	Length	Info
211	86.038199	172.24.20.31	171.64.20.62	TCP	74	42414 → 37697 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 SACK_PERM TSval=2741347212 TSecr=0 WS=4
212	86.038219	171.64.20.62	172.24.20.31	TCP	74	37697 → 42414 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3516241509 TSecr=2741347212 WS=128
214	86.039289	172.24.20.31	171.64.20.62	TCP	66	42414 → 37697 [ACK] Seq=1 Ack=1 Win=65536 Len=0 TSval=2741347213 TSecr=3516241509
216	86.040282	171.64.20.62	172.24.20.31	FTP-DA	95	FTP Data: 29 bytes (PASV) (RETR global_thermonuclear_war.gamrules.txt)
217	86.040316	171.64.20.62	172.24.20.31	TCP	66	37697 → 42414 [FIN, ACK] Seq=30 Ack=1 Win=65280 Len=0 TSval=3516241511 TSecr=2741347213
218	86.040712	172.24.20.31	171.64.20.62	TCP	74	42414 → 37697 [ACK] Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347215 TSecr=3516241511
219	86.040918	172.24.20.31	171.64.20.62	TCP	66	42414 → 37697 [ACK] Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347217 TSecr=3516241511
220	86.042257	172.24.20.31	171.64.20.62	TCP	66	42414 → 37697 [FIN, ACK] Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347217 TSecr=3516241511
221	86.042264	171.64.20.62	172.24.20.31	TCP	66	37697 → 42414 [ACK] Seq=31 Ack=2 Win=65280 Len=0 TSval=3516241513 TSecr=2741347217

```
> Frame 216: Packet, 95 bytes on wire (760 bits), 95 bytes captured (760 bits)
> Ethernet II, Src: VMware_58:4f:6e (00:0c:29:58:4f:6e), Dst: PaloAltoNetw_ea:40:10 (b4:0c:25:ea:40:10)
> Internet Protocol Version 4, Src: 171.64.20.62, Dst: 172.24.20.31
> Transmission Control Protocol, Src Port: 37697, Dst Port: 42414, Seq: 1, Ack: 1, Len: 29
  FTP Data (29 bytes data)
    [Setup frame: 210]
    [Setup method: PASV]
    [Command: RETR global_thermonuclear_war.gamrules.txt]
    Command frame: 213
    [Current working directory: ]
  Line-based text data (1 lines)
    https://tinyurl.com/yr5zprz4n
```

Paste the link into google



Question 3: Interpret an Nmap Output

1. What can an attacker do with each port?

Port 21 (FTP – vsftpd 2.3.4)

An attacker can try anonymous login or brute-force the FTP credentials. If successful, the attacker may upload or download files from the server. Since vsftpd 2.3.4 is an old version, it may also allow attackers to gain shell access through known exploits.

Port 22 (SSH – OpenSSH 5.3p1)

An attacker may try brute-force attacks to guess the username and password. If the credentials are weak, the attacker can get remote command-line access to the machine.

Port 80 (HTTP – Apache HTTP Server 2.2.8)

An attacker can access the website and look for web vulnerabilities such as outdated modules, file inclusion, or directory traversal. Sensitive files and hidden directories may also be exposed.

Port 139 (NetBIOS)

This port can allow attackers to gather information such as shared folders, usernames, and system details from the network.

Port 445 (SMB – Windows Sharing)

An attacker can attempt to access shared folders or exploit SMB vulnerabilities. SMB services are often targeted because they can give deeper access into the system.

2. What vulnerabilities are likely present based on the version?

FTP – vsftpd 2.3.4

This version is known to have a backdoor vulnerability which may allow remote shell access to attackers.

SSH – OpenSSH 5.3p1

This is an outdated version and may be vulnerable to brute-force attacks or weak SSH configurations.

HTTP – Apache HTTP Server 2.2.8

Apache 2.2.8 is outdated and may contain known vulnerabilities such as directory traversal or remote code execution depending on the server setup.

SMB – Windows 7 Professional SP1

Windows 7 SP1 is already end-of-life and vulnerable to SMB exploits like EternalBlue, which was used in WannaCry ransomware attacks.

3. Which one is the highest risk and why?

Port 445 (SMB – Windows 7 SP1) is the highest risk because SMB vulnerabilities such as EternalBlue are very dangerous. Attackers may exploit the system remotely and gain full access without needing valid credentials in some situations.

4. What attack path can be built from this?

An attacker may first scan the target and gather information from Port 80. Then, the attacker may exploit the FTP service on Port 21 to gain initial access. After entering the system, the attacker can enumerate SMB shares using Ports 139 and 445. Finally, the attacker may exploit SMB vulnerabilities such as EternalBlue to gain full control of the machine and maintain access through SSH if credentials are found.

5. What should be the remediation?

The best remediation is to update and patch all outdated services and operating systems, especially Windows 7 SP1, because most of the vulnerabilities come from old and unsupported software versions.

Question 4: Identify the OS (OS Fingerprinting) - TTL

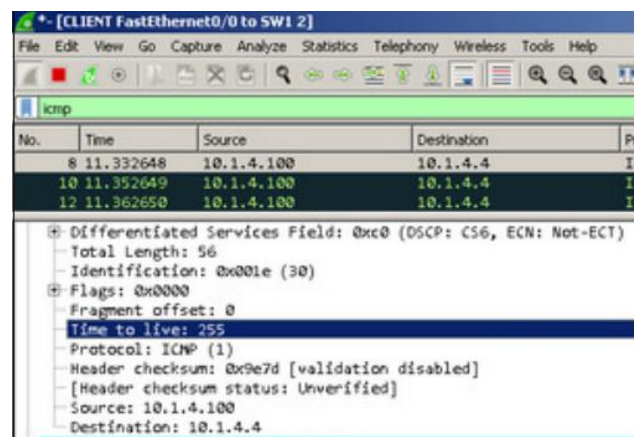
Image 1

```
[sk@ostechnix ~]$ ping -c5 localhost
PING localhost (localhost (:::1)) 56 data bytes
64 bytes from localhost (:::1): icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from localhost (:::1): icmp_seq=2 ttl=64 time=0.057 ms
64 bytes from localhost (:::1): icmp_seq=3 ttl=64 time=0.070 ms
64 bytes from localhost (:::1): icmp_seq=4 ttl=64 time=0.067 ms
64 bytes from localhost (:::1): icmp_seq=5 ttl=64 time=0.056 ms

--- localhost ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4096ms
rtt min/avg/max/mdev = 0.056/0.062/0.070/0.005 ms
```

= The TTL value shown is 64, which commonly indicates that the operating system is Linux or Unix-based. Therefore, the detected OS is most likely Linux.

Image 2



= The TTL value shown in the packet is 255. A TTL value of 255 usually indicates that the operating system is a network device such as a Cisco router or switch.

Image 3

```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

= The TTL value shown is 128, which commonly indicates that the operating system is Windows. Therefore, the detected OS is most likely Windows.

Question 5: Analyse the Nessus file

My Basic Network Scan / Plugin #134862
[← Back to Vulnerability Group](#)

Hosts 1 Vulnerabilities 72 Remediations 4

CRITICAL Apache Tomcat AJP Connector Request Injection (Ghostcat)

Description
A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

1. What is the affected Port number

8009 / tcp / ajp13 192.168.232.139

2. What is the Affected protocol

Apache Tomcat AJP

3. What is the CVSS Score of vulnerability found

☐ Sev	CVSS ▼	VPR	EPSS
☐ CRITICAL	9.8	9.6	

4.Can you find any exploit related to this vulnerability?

Yes, there are public exploits available for Ghostcat (CVE-2020-1938) that allow attackers to read sensitive files and potentially achieve remote code execution via the AJP port

5.Find CVE for this vulnerability.

CVE: CVE-2020-1938, CVE-2020-1745